

阶段1: 基础入门 — 网络安全导论 — 渗透测试基础 — 网络基础 — Linux操作系统基础 — WEB安全基础 — 数据库基础 — 编程基础 — CTF基础 — 阶段你收获什么? — 综合年收入15w+

- 网络安全行业简介
 - 行业前景
 - 历史
 - 重要事件
- 网络安全意识与法律法规
 - 安全意识
 - 法律法规
 - 案例
- 网络安全管理概述 — 安全运营、运维、模型
- 等保测评 — 等保简介、等保规定、流程和规范

- 计算机网络简介
 - 计算机网络基础、协议和架构
 - 网络通信原理、OSI模型、数据转发流程
 - 常见协议解析 (HTTP、TCP/IP、ARP等)
- 计算机网络安全
 - 网络安全防御与攻击技术介绍
 - Web漏洞原理与防御
 - 主动/被动攻击、DDOS攻击、CVE漏洞复现

- Web前端基础
 - Web发展史、基本概念和协议
 - HTML、CSS和JavaScript简介
- Web安全漏洞
 - OWASP Top10
 - Web漏洞扫描工具
 - Web渗透工具之Nmap
 - Web渗透工具之BurpSuite
 - Web渗透工具之SQLMap
 - Web渗透工具之其他 (菜刀、漏扫)

- PHP编程基础
 - PHP开发环境配置
 - PHP基础语法
 - PHP函数
 - PHP数组
 - PHP错误处理与调试
 - PHP表单与Web操作
 - PHP操作数据库
 - PHP正则表达式

- Python编程基础
 - Python开发环境配置
 - Python基础语法之字符串
 - Python基础语法之列表与元组
 - Python基础语法之集合与字典
 - Python基础语法之控制流程
 - Python函数与模块
 - Python正则表达式
 - Python爬虫基础

- 渗透测试概述 — 流程、分类、标准
- 主机攻防演练 — MS17-010、MS08-067、MS10-046、MS12-20等
- 信息搜集技术 — 主动/被动信息搜集、Nmap工具、Google Hacking
- Web信息搜集技术 — 域名、C段、旁站、目录、后台、端口、指纹
- 漏洞扫描 — 概念、工具、方法
- 漏洞利用 — 漏洞原理、利用方法、工具 (MSF)、绕过IDS和反病毒引擎
- 后期利用 — 提权、跳板攻击、免杀、持续控制、消除痕迹
- 渗透报告 — 报告书写、模板、格式标准等

- 操作系统简介 — 操作系统定义、历史、功能、分类
- Windows系统常见功能和命令
- Kali Linux系统常见功能和命令
- 操作系统安全
 - 操作系统安全简介
 - 系统入侵排查
 - 系统加固基础

- 数据库简介 — 数据库基本概念
- SQL语言基础
- 数据库安全加固
 - 数据库安全概述和加固原则
 - 数据库加固实操 (MySQL、Oracle或SQLServer)

- CTF简介 — CTF发展史、赛制和赛程规划
- 密码学基础
 - 密码学概述
 - 古典密码学 (凯撒、栅栏、换位等)
 - 现代密码学 (对称/非对称加密算法, 哈希函数等)
- CTF竞赛题型
 - 密码学类题型
 - Web类题型
 - 隐写类题型
 - 杂项类题型
 - 二进制类题型

网络安全渗透测试学习计划 (2025版)

一、基础准备阶段 (2天)

- day1.1 确认环境: Kali Linux安装、虚拟机配置、渗透工具初始化
- day1.2 名词与渗透流程: 核心名词 (漏洞/Payload/Shell)、标准流程 (信息收集→报告输出)

二、Web安全核心漏洞学习 (18天)

- 信息收集 (day2-day3, 2天): 主动/被动收集、工具 (Nmap/Dirsearch/Fofa)
- 暴力破解 (day4, 1天): Web场景、Burp Suite Intruder、密码字典与防御
- XSS跨站脚本 (day5, 1天): 存储型/反射型/DOM型、利用场景 (Cookie窃取)
- SQL注入 (day6-day8, 3天):
 - day6: 原理与MySQL Union/报错注入
 - day7: 布尔/时间盲注、多数据库差异
 - day8: SQLMap使用、预编译防御
- 文件上传/下载 (day9, 1天): 上传绕过 (前端/后端)、webshell利用、任意文件读取
- 文件包含/CSRF (day10, 1天):
 - 文件包含: 原理/协议/防御
 - CSRF: 原理/利用场景、Token/Referer防御
- 命令执行/RCE (day11, 1天): 命令与代码执行差异、JBoss/Struts2漏洞、工具验证
- SSRF + Redis (day12-day13, 2天):
 - day12: SSRF原理/防御/协议
 - day13: Redis未授权访问利用
- XXE外部实体注入 (day14, 1天): XML注入原理、文件读取/端口探测、外部实体防御
- 逻辑漏洞 (day15.1, 0.5天): 越权/密码重置缺陷、数据篡改、验证码绕过
- JS前端解密 (day15.2, 0.5天): 前端加密方式/工具使用
- 反序列化漏洞 (day16-day18, 3天):
 - day16: 序列化原理、多语言差异
 - day17: Fastjson/Struts2/Log4j漏洞、框架利用实战
 - day18: 云环境渗透、序列化校验防御
- 扫描工具 (day19, 1天): Appscan/AWVS/Nessus、结果分析 (误报/漏报)、自动化+手动结合

三、工具实战与场景渗透 (8天)

- Metasploit (MSF) (day20, 1天): 电脑/安卓木马利用、ms17_010模块、主机漏洞利用
- Cobalt Strike (CS) (day21, 1天): Payload生成、主机上线、基础功能
- 安全报告分析 (day22, 1天): 报告结构、漏洞验证、修复方案、甲方汇报模拟
- App渗透 (移动端) (day23, 1天): 模拟器/抓包配置、Frida使用
- 代码审计 (day24, 0.5天): 审计思路、Fortify工具、漏洞定位与修复方案
- 护网 (红蓝对抗) (day24.5, 0.5天): 对抗流程、红队策略/蓝队手段、安全设备讲解
- 应急响应 (day25-day26, 2天):
 - day25: 应急流程、webshell清除、勒索病毒应对
 - day26: 火绒剑/D盾查杀、攻击源定位、靶场实战

四、内网渗透学习 (2天)

- 纵向提权 (day27, 1天): Windows (MS17-010)、Linux (SUID/内核漏洞)、提权工具
- 横向渗透 (day28, 1天): 内网信息收集、frp/Neo内网穿透、多场景实战

五、高级攻防与合规 (1天)

- 绕WAF (day29, 0.5天): WAF工作原理、Payload变形/编码绕过
- 等保合规 (day29.5, 0.5天): 等保2.0标准、测评流程、与渗透测试关联